Minor Project Assessment Part 2 — IDOR, CORS & File Upload

October Batch | Mini-Project Assessment — Part 2

Batch	October Batch
Assessment period	Access Control & Upload Security Phase — Part 2 (IDOR, CORS, File Upload)
Topics / vulnerabilities covered	IDOR (API/BOLA), CORS Misconfiguration, Unrestricted File Upload
Builds on	the Netcraft / Webalizer / Shodan / Subdomain Enumeration / Burp Suite reconnaissance modul
Total tasks	5 (as listed below)
Submission format	Written report (PDF/Word) with screenshots of each step, per task

Scope & Authorization Notice

This mini-project is for authorized, educational use only, inside an isolated lab environment or against targets for which written permission has been obtained. Trainees must not run any of these tools or techniques against systems they do not own or do not have explicit authorization to test. No destructive payload or web shell should ever be executed outside the controlled lab, and findings must be handled confidentially and used only for learning assessment.

Instructions for Trainees

- Complete all tasks below in order, using only the authorized lab environment/VM provided.
- For every task, record: the exact steps/configuration used, screenshots of key request/response pairs, and a short written observation.
- Submit one consolidated report covering all 5 tasks, with Burp Suite request/response evidence included as an appendix.
- Do not execute any uploaded file or script against a system outside the designated lab; the assessment focuses on detection, bypass demonstration and remediation, not real-world exploitation.
- Each task is independently evaluated; partial completion still earns partial credit.

Assigned Tasks

Task 1: CORS Misconfiguration Assessment

Objective: Identify a lab API/application exposing permissive CORS headers and demonstrate the cross-origin data-exposure risk without exfiltrating any real user's data.

Suggested lab target: A lab app/API with a configurable or intentionally misconfigured CORS policy (e.g., DVWA extension, a custom test API, or PortSwigger Web Security Academy CORS labs)

Steps to perform:

1. Send requests to the target API from different Origin values using Burp Repeater and record how Access-Control-Allow-Origin responds each time.
2. Check specifically whether the server reflects an arbitrary Origin back and simultaneously sets Access-Control-Allow-Credentials: true.
3. Test whether the literal value 'null' is trusted as an origin.
4. Describe (in your report, without needing to actually run it against a live victim) how a hosted attacker page using fetch() with credentials included could read the authenticated response if the misconfiguration exists.

© 2025 UnloxAcademy. All Rights Reserved.
Made by recycled paper, because we care.

5 Recommend a strict origin-allowlist fix and re-test to confirm it would block the earlier bypass attempts.

Deliverables to submit:

- Burp Repeater request/response pairs for each Origin value tested
- A finding note stating whether the app is vulnerable and why
- Recommended fix and how you would verify it

Evaluation focus: Correct identification of the misconfiguration pattern and soundness of the proposed fix

---

Task 2: API-Level IDOR (BOLA) Testing

Objective: Test a multi-user lab application's API for object-level authorization flaws, building on the IDOR concepts covered previously, now focused on API endpoints.

Suggested lab target: A lab app with at least two distinct user accounts and an API returning per-user objects (orders, profile, documents)

Steps to perform:

1 Log in as User A, capture a request that fetches one of User A's objects, and note its ID.
2 Replay the same request (same session/token) after changing only the object ID to one likely belonging to User B.
3 Separately, log in as User B and confirm whether User A's data was in fact accessible without authorization.
4 If an API returns a list/array of objects, check whether it is correctly filtered to the caller's own data only.
5 Document the exact authorization check that is missing on the server side.

Deliverables to submit:

- Side-by-side request/response evidence for both accounts
- Clear statement of what data was exposed across accounts
- Recommended server-side authorization fix (ownership/role check)

Evaluation focus: Rigor of the cross-account testing and clarity of the authorization-gap explanation

---

Task 3: Unrestricted File Upload — Filter Bypass

Objective: Attempt to bypass a lab application's file-upload filters using at least three different documented bypass techniques, without executing any uploaded file.

Suggested lab target: DVWA File Upload module (low/medium) or a similar lab upload feature

Steps to perform:

1 Attempt a direct upload of a disallowed file type and record how it is blocked.
2 Attempt a double-extension bypass (e.g., renaming to end in an allowed extension after a blocked one).
3 Attempt a case-manipulation bypass on the extension.
4 Attempt a Content-Type header spoof using Burp Repeater/Proxy to relabel the upload as an allowed type.
5 Record which techniques succeeded and which were correctly blocked, without executing any uploaded file.

Deliverables to submit:

- A table of techniques attempted vs. outcome (blocked/bypassed)
- Screenshots of the relevant Burp requests for each attempt
- Explanation of exactly why each successful bypass worked

Evaluation focus: Thoroughness of the bypass attempts and accuracy of the root-cause explanation

---

Task 4: File Upload — Impact & Containment Review

Objective: Reason through the real-world impact of a successful upload bypass from Task 3, and evaluate what containment controls would have stopped it, without executing any payload.

Suggested lab target: Same lab environment as Task 3

Steps to perform:

© 2025 UnloxAcademy. All Rights Reserved.
Made by recycled paper, because we care.

1. Based on the bypass(es) that succeeded in Task 3, describe what an attacker could do next if the server were configured to execute scripts in that upload location.
2. Check (by inspection/configuration review in the lab, not live exploitation) whether the upload directory has script execution enabled.
3. Evaluate whether magic-byte/content validation was present, and if not, explain what it would have caught.
4. Evaluate whether the uploaded file was stored under its original name/path (predictable) or randomized.
5. List, in priority order, the containment controls that would have stopped this chain even if the filter itself were bypassed.

Deliverables to submit:

- Written impact analysis (what could have happened, in the lab's context)
- Checklist of which containment controls were present/absent
- Prioritized list of recommended containment fixes

Evaluation focus: Realism of the impact reasoning and completeness of the containment checklist

Task 5: Consolidated Vulnerability Report & Remediation Plan

Objective: Combine the CORS, IDOR and File Upload findings from Tasks 1 to 4 into a single, professional vulnerability report with severity ratings and a prioritized remediation roadmap.

Suggested lab target: Your own findings from Tasks 1 to 4

Steps to perform:

1. Summarize each finding in one paragraph: vulnerability, evidence, impact.
2. Assign a qualitative severity (Critical/High/Medium/Low) to each finding and justify it.
3. Propose a specific remediation for each finding, referencing the relevant control (allowlist, server-side authorization, content validation, execution restriction, etc.).
4. Produce a prioritized remediation roadmap (what to fix first and why).
5. Reference how this builds on the Netcraft / Webalizer / Shodan / Subdomain Enumeration / Burp Suite reconnaissance modules already completed by the batch.

Deliverables to submit:

- One consolidated report (3-5 pages) covering all three vulnerability classes
- Severity justification for each finding
- A prioritized remediation roadmap

Evaluation focus: Professional quality of the report and soundness of severity/priority judgments

Overall Evaluation Rubric

Criteria	Weight
Correct and complete execution of each task	40%
Quality & clarity of documentation (steps, screenshots, evidence)	25%
Depth of analysis / understanding of root cause and impact	20%
Adherence to scope, ethics and quality of remediation advice	15%

Generated for internal training assessment purposes.

© 2025 UnloxAcademy. All Rights Resereved.

Made by recycled paper, because we care.